

Project Report: Museum Ticketing & AI Cultural Guide

Project: Museum Ticketing & AI Cultural Guide

Author: Alessio Manera (Student ID: 905639)

Group: Group-11 (single-person group)

Course: Lab of Web Technologies (AY 2025/26), Prof. Zeynep Yucel, Ca' Foscari University of Venice

Submission date: September 4, 2026

Repository: <https://github.com/alessiomanera/web-tech-lab-2026>

1. Description and Goals

The problem

Booking a cultural visit in Italy is fragmented and high-friction. Ticketing is spread across dozens of venue-specific portals with inconsistent flows. Deciding *what* to see is left entirely to the visitor and a pile of browser tabs, which is hardest exactly when it matters: a limited time budget, a mixed-age group, or a specific interest such as Renaissance painting or Ancient Rome. No single place both sells the ticket and helps plan the visit.

The solution

I built a full-stack web application that does both. It presents a curated catalog of 12 bookable cultural experiences across six Italian cities (Florence, Rome, Venice, Milan, Turin, Naples), backed by 12 museums and cultural sites, one per experience. Alongside the catalog sits a conversational AI concierge that recommends experiences drawn from that same catalog and can place a ready-to-book card directly into the chat. Recommendations are grounded in the application's own relational database rather than the model's open-ended knowledge, so the assistant only suggests things that exist and can actually be booked.

The four modules

- 1. User authentication and cultural profiling.** Registration and login using Flask server-side sessions and Werkzeug PBKDF2 password hashing. An account dashboard lists digital passes and past visits, and a persisted Markdown "Cultural Taste Profile" is updated by the concierge as the conversation reveals preferences.
- 2. Experience and museum catalog directory.** A dynamic catalog with relational filtering by city, theme, and free-text keyword search, plus per-experience detail pages covering duration, pricing, inclusions, and highlights.
- 3. Four-step ticketing and reservation engine.** A booking wizard: choose the package, pick add-ons, select a visit date and time slot, and receive an instant digital pass with a unique booking code. After the visit, the user can leave a 1 to 5 star rating and a written review, gated to bookings they actually own.
- 4. Grounded AI cultural concierge.** This is the core feature. Conversational discovery runs on the Google Gemini API using Retrieval-Augmented Generation (RAG): the live `experiences` catalog is injected into the model's system instruction so it can only recommend real, bookable packages. The model emits an in-band `[RECOMMEND: id=..., title=..., city=..., price=...]` protocol tag that the front end parses into a bookable card, and it writes back a structured Markdown taste profile that persists across sessions.

This path needs a Gemini API key. Without one, or if an API call fails mid-session, the concierge falls back to a limited keyword-matching mode: it matches the message against catalog cities and themes and returns a single templated recommendation card. The fallback performs no RAG grounding, no multi-factor reasoning, and no taste-profile extraction. It exists as a network and quota safety net so the rest of the application stays navigable during evaluation; it is not an equivalent of the real concierge.

2. How to Run the Application

Prerequisites

- Python 3.10 or newer
- Git, only needed if cloning. If you already have this project as a folder (for example, unzipped from a Moodle submission), skip Git and start at "Create and activate a virtual environment" below, from inside that folder.
- An internet connection, to install dependencies and optionally to reach the Gemini API.

Setup

```
git clone https://github.com/alessiomanera/web-tech-lab-2026.git
cd web-tech-lab-2026

# Create and activate a virtual environment
python -m venv venv
# Windows (PowerShell): .\env\Scripts\Activate.ps1
# -> if PowerShell refuses with "running scripts is disabled on this system",
#     run this first, then retry the line above:
#     Set-ExecutionPolicy -Scope Process -ExecutionPolicy Bypass
# Windows (cmd): .\env\Scripts\activate.bat
# macOS / Linux: source venv/bin/activate
# Your prompt should now start with "(venv)". That confirms it worked.

pip install -r requirements.txt # installs 3 packages: Flask, python-dotenv, google-generativeai

# Copy the environment template
cp .env.example .env # Windows: copy .env.example .env

python seed.py # create and populate the database; look for
               # "Database successfully seeded..." to confirm it worked
python app.py # start the development server; look for
              # "Running on http://127.0.0.1:5000"
```

Then open `http://127.0.0.1:5000/` in a browser. If that port is already taken on your machine ("Address already in use", common on macOS where AirPlay Receiver defaults to port 5000), either free port 5000 or start the app on another one with `python -c "from app import create_app; create_app().run(port=5001)"`, then open `http://127.0.0.1:5001/` instead.

The two `.env` settings

`.env` (copied from `.env.example` above) holds two settings. Both are worth understanding before assuming something is broken:

- `FLASK_SECRET_KEY` signs login session cookies. You do not need to change it to run or evaluate the project: the placeholder works fine locally, and it only matters for a real internet-facing deployment, which this is not.
- `GEMINI_API_KEY` is recommended for full evaluation, as described below. Unlike the secret key, this one does change what you see if you leave the placeholder in place.

Gemini API key, recommended for full evaluation

The AI Cultural Concierge (module 4) is the core feature of the project, and it runs on the Google Gemini API. To evaluate it properly, set a key:

1. Go to [Google AI Studio](#) and sign in with any Google account.
2. Click **Create API key**.
3. Copy the key and paste it into `.env` as `GEMINI_API_KEY=`, replacing `your_gemini_api_key_here`. This takes about two minutes and needs no credit card.

The model defaults to `gemini-flash-lite-latest` and can be overridden with `GEMINI_MODEL`. With a key, the concierge performs RAG grounding on the live catalog and extracts a persistent taste profile from the conversation.

Without a key the app still starts and every other module works, but the concierge drops to a labelled offline demo mode: a deterministic keyword matcher that returns one templated recommendation card, with no RAG grounding and no taste-profile updates. The concierge view shows a banner while this mode is active. The fallback is a resilience feature covering network and quota failures, not a substitute for the real concierge.

Demo account

`seed.py` creates a ready-to-use account with a pre-populated Cultural Taste Profile, so the booking flow, concierge, and dashboard are all populated on first login:

Email	Password
<code>alessio@example.com</code>	<code>password123</code>

You may also register a fresh account at `/register`.

Warning: `seed.py` drops and recreates every table. Any accounts or bookings created since the last seed are permanently deleted. Run it once on first setup, or whenever a clean demo state is wanted.

3. Contributions and Roles

Group-11 is a single-person group, so every decision behind this project is mine: the competitor research, the architecture and technology choices (including moving off Flask-SQLAlchemy to raw `sqlite3`), the Neubrutalism design system, the test suite, and the documentation. No other people were involved.

For clarity, here is how the work breaks down by workstream, all of it carried out by me:

Workstream	Concrete artifacts produced
Database and schema design	<code>schema.sql</code> (relational DDL for <code>users</code> , <code>museums</code> , <code>exhibitions</code> , <code>experiences</code> , <code>tickets</code> , with <code>ON DELETE CASCADE</code> on <code>tickets</code> and <code>ON DELETE SET NULL</code> on <code>experiences.museum_id</code>); <code>database.py</code> (per-request <code>sqlite3</code> connection context manager with <code>PRAGMA foreign_keys = ON</code>); <code>seed.py</code> (12 museums, 12 curated experiences across 6 cities, demo account).
Backend and REST API	<code>app.py</code> (application factory, 400/404/500 handlers); <code>routes.py</code> (page routes plus <code>/api/book</code> , <code>/api/chat</code> , <code>/api/feedback</code> , <code>/api/profile/reset-memory</code>); <code>auth.py</code> (registration, login, logout, <code>@login_required</code> , safe next redirect handling). Parameterized SQL throughout.
AI and RAG integration	<code>_call_gemini_concierge()</code> in <code>routes.py</code> : RAG prompt construction grounded on the live catalog, the <code>[RECOMMEND: ...]</code> in-band protocol, Markdown taste-profile extraction and persistence, and the local heuristic fallback matcher.
Frontend and design system	13 Jinja2 templates (12 child templates extending the master <code>base.html</code> layout); the vanilla Neubrutalist CSS system (<code>variables.css</code> , <code>layout.css</code> , <code>components.css</code> , <code>utilities.css</code>); six vanilla JavaScript files (<code>main.js</code> , <code>api.js</code> , <code>ui.js</code> , <code>bookingWizard.js</code> , <code>concierge.js</code> , <code>profile.js</code>) loaded with <code>defer</code> in dependency order from <code>base.html</code> . These are classic scripts sharing a global scope rather than ES modules, because the app ships without a bundler or build step. Also the anti-FOUC theme bootstrap and the light/dark toggle.
QA and test suite	<code>tests/</code> : 65 <code>unittest</code> integration tests against isolated temporary SQLite databases, covering database constraints, authentication, catalog filtering, booking arithmetic, concierge RAG and fallback, the feedback loop and its validation, and the custom error pages.
Documentation	<code>README.md</code> , <code>DOCS/1-Page_Project_Proposal.md</code> , <code>DOCS/Competitor_Analysis.md</code> , <code>ROADMAP.md</code> , <code>LICENSE</code> , and this report.

With no team to divide work across, I have addressed the *collaboration and group structure* dimension by making individual authorship complete and legible: every workstream above maps to concrete files, and the development history of more than 75 commits shows the work happening incrementally rather than arriving in one drop.

4. Architecture Overview

The application uses the Flask application-factory pattern. `create_app(test_config=None)` builds and configures the app, and passing a `test_config` lets the test suite point each test at its own throwaway SQLite file, so tests never touch a shared database.

Request lifecycle:

```

Browser
| HTTP request
▼
Flask routing -> Blueprint view (main_bp in routes.py / auth_bp in auth.py)
|
▼
get_db() -> per-request sqlite3 connection (PRAGMA foreign_keys = ON, Row factory)
|
▼
Parameterized SQL ( ? placeholders only, no string interpolation anywhere )
|
└-> Jinja2 template render -> HTML response (page routes)
└-> jsonify(...) -> JSON response (/api/* routes consumed by fetch)

```

- **No ORM.** All persistence is raw `sqlite3` with parameterized queries. I chose this to keep the data layer transparent and auditable, and because it matches the database pattern demonstrated in the course's own `week_5_database_exercise`: raw `sqlite3`, `Row` factory, hand-written SQL, and Werkzeug hashing.
- **Blueprints** separate authentication (`auth_bp`) from the core application (`main_bp`).
- **Sessions** use Flask's signed cookies, and `@login_required` gates the booking wizard, concierge, and profile.
- **Error handling** is centralised: `abort(404)` and unhandled errors render branded `400.html`, `404.html`, and `500.html` pages.

5. Testing

```
python -m unittest discover -s tests -p "test_*.py" -v
```

65 tests, all passing. They run at integration level, using the real Flask test client against a real SQLite database, isolated in a temporary file that is created and destroyed per test.

Module	What it proves
<code>test_database.py</code>	<code>PRAGMA foreign_keys = ON</code> is active per connection; <code>UNIQUE</code> constraints hold on email and booking code; <code>ON DELETE CASCADE</code> and <code>SET NULL</code> behave as declared.
<code>test_auth.py</code>	Registration; Werkzeug PBKDF2 hashing, with the password never stored in clear; login success and failure; session cleared on logout, which is a POST and refuses GET so it cannot be triggered cross-site; <code>@login_required</code> redirects; safe versus rejected <code>?next=</code> redirect targets, covering open-redirect protection; and CSRF enforcement, where a POST with a missing or forged token is rejected on both the HTML forms and the JSON API, GET requests are unaffected, and the same request succeeds once the token is presented.
<code>test_catalog.py</code>	City, theme, and keyword filtering produce the correct subset; detail pages render; a missing experience id renders the branded custom 404 page.

Module	What it proves
<code>test_booking.py</code>	Four-step wizard rendering; visit-date bounds, including that a date beyond the 90-day window is refused while the 90th day itself still books; time-slot validation; guest-count bounds of 1 to 6, with a fractional count rejected rather than truncated; add-on pricing arithmetic; and that add-on prices are taken from the catalog rather than the request payload.
<code>test_concierge.py</code>	Grounded Gemini RAG (mocked) parses <code>[RECOMMEND: ...]</code> tags and persists the extracted taste profile; the offline heuristic fallback matches by city and by theme; empty messages are rejected; a stored taste profile containing markup is escaped and never rendered as HTML.
<code>test_feedback.py</code>	Ratings persist; reviews are gated to the owning user, returning 404 otherwise; non-numeric ratings return 400 rather than 500; ratings outside 1 to 5 are rejected.
<code>test_errors.py</code>	Custom <code>400.html</code> , <code>404.html</code> , and <code>500.html</code> pages render with the correct status codes, and the profile dashboard renders.

6. Security Measures

Measure	Implementation
SQL injection	Parameterized queries throughout, using <code>?</code> placeholders, verified across every statement in <code>routes.py</code> , <code>auth.py</code> , <code>database.py</code> , and <code>seed.py</code> . There is no f-string or <code>%</code> -formatted SQL anywhere.
Password storage	Werkzeug <code>generate_password_hash</code> and <code>check_password_hash</code> (PBKDF2-SHA256, per-user salt). Plaintext passwords are never stored or logged.
Authentication and authorisation	Flask signed-cookie sessions; <code>@login_required</code> on the booking wizard, concierge, and profile; feedback writes verify <code>user_id</code> ownership of the target booking.
Server-side output escaping	Jinja2 autoescaping on all templates. The one former <code>safe</code> filter on user-controlled taste-profile text was removed and replaced with plain interpolation plus a CSS <code>white-space: pre-line</code> class.
Client-side output escaping	<code>concierge.js</code> escapes every HTML-significant character in user chat input, model output, and the stored taste profile before it reaches the DOM, via <code>escapeHtml</code> , with the taste profile written through <code>textContent</code> rather than <code>innerHTML</code> . <code>bookingWizard.js</code> sets add-on names the same way. This closes a reflected and stored XSS vector in the chat renderer.
Cross-site request forgery (CSRF)	Every state-changing request must present a per-session token minted with <code>secrets.token_urlsafe(32)</code> and compared with <code>secrets.compare_digest</code> . It reaches the server as a hidden <code>csrf_token</code> field on the HTML forms and an <code>X-CSRFToken</code> header on the JSON endpoints, enforced centrally by a <code>before_request</code> hook rather than per route. I implemented it directly rather than pulling in Flask-WTF, so the mechanism stays visible in the codebase. As a second layer, the session cookie is set <code>HttpOnly</code> and <code>SameSite=Lax</code> explicitly, so the browser will not attach it to a cross-site POST in the first place. Logout is a POST for the same reason: a GET logout can be triggered by anything that loads a URL, including an <code></code> tag on a third-party page.

Measure	Implementation
Open-redirect protection	The post-login <code>?next=</code> target is accepted only if it is a same-site relative path. Absolute URLs and protocol-relative <code>//</code> targets are discarded and the user is sent to the home page.
Server-side pricing integrity	A booking request may only name <i>which</i> add-ons it wants. <code>create_booking()</code> re-reads each add-on's name and price from the chosen experience's own catalog entry, drops unknown ids, and collapses duplicates, so a crafted payload cannot invent an add-on or discount the total. Two regression tests cover this.
Booking-code collisions	Booking codes are <code>EXP-2026-</code> plus six random alphanumerics on a <code>UNIQUE</code> column. Insertion retries on the rare <code>IntegrityError</code> instead of surfacing a 500.

7. Known Limitations

These are the honest scope boundaries of what I delivered:

- **Session-scoped CSRF tokens.** The token lives in the signed session cookie and lasts as long as the session, rather than rotating per form. That is the standard trade-off for a server-rendered app of this size; per-request rotation would break the back button and concurrent tabs without meaningfully raising the bar here.
- **The concierge is single-turn.** No running conversation history is sent to Gemini. Continuity between messages is carried only by the persisted Cultural Taste Profile.
- **RAG grounding covers the `experiences` table only**, meaning the 12 bookable packages. It does not ground on `museums` or `exhibitions`, and it does not know venue logistics such as street addresses, general opening hours, or physical accessibility.
- **`exhibitions` is schema-only.** The table exists in `schema.sql`, is populated by `seed.py`, and enforces a foreign key to `museums`, but no route or template currently reads from it.
- **No payment integration.** Booking issues a digital pass and a booking code; no money changes hands.
- **No capacity or inventory model.** Time slots never sell out, and there is no per-slot seat count. Bookings are accepted from today up to 90 days ahead, enforced on the server as well as in the date picker.
- **Not a production deployment.** SQLite and the Flask development server are appropriate for this assignment and for local evaluation, not for production traffic.
- **Responsive coverage** is verified at 320, 375, 768, and 1440 px across every page, with no horizontal overflow at any width. The layout is nonetheless designed desktop-first: a phone gets a correct stacked layout rather than a purpose-built mobile experience.